

Security Runbook — 108 AI Desktop Agent

Audience: operatore / consulente che deploia l'agent su macchina cliente PMI.

Modello di minaccia

L'agent gira on-premise con accesso a:

- File system (directory consentite in config)
- Shell locale (con guardrail)
- Clipboard, automazione desktop (opzionale)
- Integrazioni email/calendario/messaging
- Secret provider LLM in ~/.108ai/providers/

Assunzione: la macchina host può essere compromessa; l'agent non deve amplificare l'impatto (no secret in log, sandbox comandi, rate limit).

Dati sensibili

Dato	Dove	Mitigazione
JWT gateway	config.json	Permessi file utente; rinnovo OAuth
API key LLM	providers/*.json (vault)	hardening/key-vault.ts, no log
Email/PEC	Integrazioni OAuth/IMAP	Minimizzazione in log; PII guard su output LLM
Cronologia agent	~/.108ai/agents/history/	Retention per max_conversation_length

Controlli implementati

Input LLM (hardening/llm-sanitize.ts)

Blocca pattern noti di prompt injection prima della chiamata gateway.

Output PII (hardening/pii-guard.ts)

Scansione e redazione email/telefoni/CF su risposte prima di mostrarle all'utente.

Secrets (extensions/security/secrets.ts)

Mascheramento in UI/log; install guard per path non consentiti.

Sandbox comandi (extensions/security/sandbox.ts)

Lista deny per comandi shell pericolosi.

Job Engine: gli step shell sono soggetti alla stessa validazione (validateShellCommand) e sono bloccati se:

- commands.allow_shell: deny in ~/.108ai/permissions.yml
- shellEnabled: false in ~/.108ai/config.json

Rate limiting (extensions/security/rate-limit.ts)

Limite azioni/minuto configurabile.

Audit log (`~/108ai/audit.log`)

Rotazione automatica (hardening/audit-rotation.ts).

Web UI (`/ui web`)

- Bind solo 127.0.0.1 — non esporre su LAN senza reverse proxy + auth
- CORS * su API locale: accettabile solo perché non raggiungibile dall'esterno
- Non deployare la dashboard in produzione multi-utente senza hardening aggiuntivo

MCP

- Eseguire solo server MCP da fonti fidate
- Ogni server stdio eredita permessi utente OS
- Verificare tool esposti con /mcp tools prima dell'uso in produzione
- Preferire /mcp install (npm/git/preset) con sorgenti HTTPS e pinning --ref quando possibile

Store

Firma autore (publisher attestation)

I pacchetti scaricati dal catalogo possono includere una firma HMAC sul payload:

```
author[name|version|sha256(content)
```

Chiave: AIA_STORE_SIGNING_KEY (globale) o AIA_STORE_KEY_<AUTHOR> per publisher.

Policy consigliata:

- pacchetti verified=true bundled → consentiti anche senza firma (trust locale)
- pacchetti da installUrl → richiedere firma valida (o force solo in debug)

Audit install

Ogni install scrive una entry in ~/108ai/extensions-lock.json con checksum + timestamp.

WhatsApp / Telegram

- Baileys e bot token sono superficie ad alto rischio ToS e abuso
- Usare account dedicati; non collegare numeri personali critici senza valutazione legale

Incident response

Sospetta esfiltrazione token

- Revocare sessione lato gateway (tenant admin)
- Eliminare ~/108ai/config.json e rifare login
- Ruotare API key provider in providers/
- Controllare audit.log per azioni anomale

Prompt injection riuscito

- Identificare sessione e input in cronologia shell
- Verificare che sanitize rules coprano il pattern → PR su llm-sanitize.ts

- Se dati sensibili esposti: notifica GDPR secondo policy cliente

MCP server compromesso

- /mcp stop (o riavvio agent)
- Rimuovere entry da mcp.yml
- Audit file system per modifiche recenti

Checklist go-live cliente

- [] allowedDirectories minimizzate
- [] desktopEnabled false se non necessario
- [] Provider LLM con budget/limiti tenant
- [] Backup ~/.108ai schedulato (/export backup)
- [] Audit log rotation verificata
- [] Utente formato su /help e rischi messaging
- [] Nessun secret in repository git cliente

Contatti

- Bug sicurezza piattaforma 108 AI: canale privato consulenza / ticket progetto
- GDPR incident cliente: procedura del titolare del trattamento (PMI)